MODULE 20 · DOMAIN 2 - SECURITY, COMPLIANCE, AND GOVERNANCE

Organisations, Guardrails, SCPs and RCPs

Shape the organisation into OUs, vend accounts with a baseline, and choose the right policy type for each guardrail.

DOMAIN 2 of 5 EXAM WEIGHT 25% MODULE 20 of 52

admin@sthithapragna.com

Accounts are the strongest boundary AWS has. **OUs** group them by policy, and **guardrails** follow the OU.

A typical OU structure

OU	HOLDS	GUARDRAIL EMPHASIS
Security	Log archive, security tooling	Locked down; few humans
Infrastructure	Networking, shared services	Network changes controlled
Workloads	Prod and non-prod sub-OUs	Prod stricter than non-prod
Sandbox	Experiments, no production data	Budgets, no connectivity
Suspended	Accounts being closed	Deny almost everything

ON THE EXAM

Group by the policies an account needs, not by the organisation chart.

Organizations policy types

POLICY	CONSTRAINS	EXAMPLE
SCP	Your principals' maximum permissions	No leaving the organisation
RCP	Maximum access to your resources	Require TLS for every caller
Declarative	Service configuration, durably	Block public AMI sharing
Backup, tag	Backup plans, tag standards	Daily backup of tagged resources
AI opt-out, Bedrock	AI service data use and settings	Opt out of content use

ON THE EXAM

Permissions are SCPs and RCPs. A service's settings are a declarative policy.

SCP or RCP?

SERVICE CONTROL POLICY

What our principals may do

- Applies to IAM users and roles in member accounts
- Follows our principals anywhere
- Cannot restrict outside principals
- Region limits, protect security tooling

RESOURCE CONTROL POLICY

What may be done to our resources

- Applies to resources in member accounts
- Constrains any caller, including outsiders
- Supported services only, such as S3, KMS, STS
- Enforce TLS, keep outsiders out

THE TIEBREAKER

Neither grants anything. Neither affects the management account or service-linked roles.

How SCPs evaluate

- **An allow is needed at every level:** root, each OU, and the account.
- **A deny at any level** wins, and children cannot undo it.
- **Full IAM language** since September 2025: conditions, NotResource, resource ARNs.
- **Exceptions by condition**, such as aws:PrincipalArn for a break-glass role.
- **Management account is never restricted**, so run no workloads there.

> ON THE EXAM
>
> If removing FullAWSAccess at an OU blocks everything below it, that is the allow-at-every-level rule.

Control Tower control behaviours

BEHAVIOUR	IMPLEMENTED WITH	ACTS
Preventive	SCPs, RCPs, declarative policies	Blocks the action
Detective	AWS Config rules	Reports after the fact
Proactive	CloudFormation hooks	Fails the stack before creation

ON THE EXAM

Before provisioning, with a clear reason to the deployer: proactive. After: detective.

Landing zones and Account Factory

- **Landing zone 4.0** (Nov 2025): Config, CloudTrail, roles and Backup integrations optional.
- **No mandatory OUs**; a controls-only setup is possible.
- **Account Factory** vends accounts into an OU with its baseline and controls.
- **Account Factory for Terraform** when account requests live in a Terraform pipeline.
- **Customizations for Control Tower** adds your own StackSets and SCPs per OU.

> ON THE EXAM
>
> Accounts created automatically, in the right OU, with guardrails and baseline: Account Factory.

Reading the scenario

WHEN THE QUESTION SAYS	IT IS TESTING
New accounts with a baseline, from a pipeline	Account Factory, or AFT with Terraform
Our staff must never do X, except break-glass	SCP deny with a principal exception
Every caller, including partners, must Y	RCP
Service setting stays enforced as APIs change	Declarative policy
Fail the deployment before creation	Proactive control
SCP does not stop the management account	Move workloads out

ON THE EXAM

Ask whose action is constrained: our principals, anyone on our resources, or the service itself.

> Meridian Freight creates about 20 new AWS accounts a month. Platform engineers manage all infrastructure in Terraform and want account requests reviewed as pull requests.
>
> Each new account must land in the correct OU with the logging baseline, guardrails and standard customisations applied automatically.

What should the solutions architect recommend?

A. AWS Control Tower with Account Factory for Terraform, placing accounts in OUs with their controls

B. A Lambda function that calls the Organizations CreateAccount API

C. CloudFormation StackSets deployed to each account after manual creation

D. One shared account per team, with IAM roles for each project

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Control Tower with AFT

Terraform-driven requests; accounts land governed, with baseline and customisations.

B CreateAccount Lambda

Creates accounts, but the baseline and controls are yours to build.

C StackSets after manual creation

Manual step, and nothing places accounts or applies controls.

D Shared accounts

Abandons the account boundary the design depends on.

THE SIGNAL

Account vending plus Terraform pull requests: Account Factory for Terraform.

> Meridian Freight wants to guarantee that no account in its Sandbox OU can share AMIs or EBS snapshots publicly, and that new EC2 instances require IMDSv2.
>
> The controls must keep working if EC2 adds new APIs that could change these settings, and account administrators must not be able to override them.

What should the solutions architect use?

A. An SCP denying the current sharing and metadata API actions

B. AWS Config rules with automatic remediation

C. IAM permissions boundaries on all roles in the Sandbox accounts

D. A declarative policy for EC2 attached to the Sandbox OU

◆ PAUSE AND DECIDE

What should the solutions architect use?

A SCP on current actions

Covers today's APIs; a new API could bypass it.

B Config remediation

Detects and reverses, leaving a window of exposure.

C Permissions boundaries

Per role, and administrators can create roles without them.

D Declarative policy

Sets the service configuration itself, regardless of which API is called.

THE SIGNAL

A setting that must stay set even as APIs change: a declarative policy.

> Meridian Freight's security team requires that no one in any member account, including account administrators, can stop CloudTrail, leave the organisation, or use Regions outside the EU.
>
> A single break-glass role must be exempt from the Region restriction.

What should the solutions architect implement?

A IAM policies in each account denying those actions

B An RCP denying those actions on every resource

C SCPs attached to the root denying those actions, with the Region deny excepting the break-glass role by aws:PrincipalArn

D Permissions boundaries on every administrator role

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A IAM policies per account

Account administrators can simply remove them.

B RCP

Constrains access to resources; leaving the organisation and Region use are principal actions.

C SCPs with an exception

Binds every member principal; the condition exempts one role.

D Permissions boundaries

Administrators can create new roles without boundaries.

THE SIGNAL

Our own principals, including admins, with a named exception: an SCP with aws:PrincipalArn.

> Meridian Freight shares S3 buckets and SQS queues in its member accounts with several logistics partners' AWS accounts.
>
> Security must ensure that every request to these resources uses TLS, whether it comes from Meridian's principals or from partners, without editing each bucket and queue policy.

What should the solutions architect implement?

A. An SCP denying requests where aws:SecureTransport is false

B. An RCP denying requests to S3 and SQS where aws:SecureTransport is false

C. An AWS Config rule that flags buckets without a TLS policy

D. A VPC endpoint policy requiring TLS

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A **SCP**

Binds Meridian's principals only; partner requests are unaffected.

B **RCP**

Applies to every caller of Meridian's resources, partners included.

C **Config rule**

Detective, and still requires editing each policy to fix.

D **Endpoint policy**

Only covers traffic through Meridian's own endpoint.

THE SIGNAL

A rule for every caller of our resources, applied centrally: an RCP.

> Meridian Freight attached an SCP to the organisation root denying all Regions outside the EU. An audit found EC2 instances running in a US Region in the management account.
>
> The SCP is attached correctly and works in member accounts.

What should the solutions architect recommend?

A Move the workloads into member accounts, and keep the management account for organisation administration only

B Attach the SCP directly to the management account

C Add an RCP with the same Region restriction

D Recreate the SCP as a declarative policy

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Move workloads out

Organisation guardrails cannot reach the management account; workloads belong elsewhere.

B Attach to management account

SCPs never restrict the management account, however attached.

C Add an RCP

RCPs do not affect the management account either.

D Declarative policy

Does not express a Region restriction, and does not fix the root cause.

THE SIGNAL

Guardrails exempt the management account by design. Keep it empty of workloads.

> Meridian Freight's teams deploy with CloudFormation. Security wants non-compliant resource properties, such as unencrypted databases or public load balancers in production, to be rejected before they are created.
>
> Developers must see which control failed, in the deployment itself.

Which Control Tower controls should the solutions architect enable?

A Detective controls backed by AWS Config rules

B Security Hub CSPM standards with findings sent to developers

C Preventive controls implemented as SCPs

D Proactive controls, implemented as CloudFormation hooks

◆ PAUSE AND DECIDE

Which Control Tower controls should the solutions architect enable?

A **Detective**

Reports after the resource exists.

B **Security Hub CSPM**

Also after the fact, and outside the deployment.

C **Preventive SCPs**

Block actions, but see few resource properties and return a generic denial.

D **Proactive**

Checks properties before creation and fails the stack naming the control.

THE SIGNAL

Before creation, on resource properties, explained in the deployment: proactive controls.

What to carry out of this module

- **OUs by required policy**; guardrails follow the OU to new accounts.
- **SCP** for our principals, **RCP** for every caller, **declarative** for settings.
- **Allow at every level, deny anywhere wins**; full IAM language in SCPs.
- **Preventive, proactive, detective** controls differ by timing.
- **Management account is exempt**: no workloads there.

> ON THE EXAM
>
> Ask whose action is constrained, and when the control must act.